

# AVANCE DE PROYECTO

## Análisis de Incidentes, Evaluación Práctica de Vulnerabilidades y Propuesta de Arquitectura Segura en la Nube



RENÉ RAFAEL ALMEIDA MARTÍNEZ AL02964622

# Avance de Proyecto

## Matriz de Riesgos

### Activos Críticos

En un entorno médico, la criticidad de un activo se mide por su impacto en la confidencialidad, integridad y accesibilidad, así como en la vida de los pacientes. Los activos son los siguientes:

1. **Historiales Médicos.** Registros clínicos de 500 pacientes. Su cifrado por Ransomware viola la confidencialidad y bloquea la continuidad asistencial.
2. **Servidores Locales.** Almacenan las bases de datos y expedientes. Si carecen de respaldos inmutables o segmentación, un ataque los compromete por completo.
3. **Monitores Cardiacos.** Equipos médicos críticos conectados a la red. Una falla o secuestro directo pone en riesgo inminente la vida del paciente.
4. **Infraestructura WiFi.** El vector de entrada inicial (credenciales predeterminadas). Su vulneración compromete toda la red interna.

### Matriz OWASP

| Factor de Riesgo | Contraseñas predeterminadas | Windows Server 2019 sin parches | Backups sin Cifrar | Phishing a Empleados | Red sin segmentar |
|---|---|---|---|---|---|
| **Nivel de habilidad del Atacante** | *BAJO-MODERADO* Cualquier script puede usar credenciales de fábrica | *MODERADO-ALTO* Explotación de vulnerabilidad es conocidas como un RDP Expuesto | *BAJO* Basta con acceso físico o de red al servidor de respaldos sin ninguna vulnerabilidad compleja | *BAJO* Plantillas de phishing son fáciles de conseguir y personalizar, no requiere programación | *MODERADO* Requiere moverse lateralmente una vez dentro, pero sin segmentación no hay barreras que lo impidan |
| **Factores de Vulnerabilidad** | *ALTO* Las contraseñas por defecto son públicas en manuales de fabricante | *ALTO* Servidor de tecnología de legado con vulnerabilidad es conocidas sin parchear | *ALTO* Los respaldos se almacenan en texto plano; si el Ransomware o un atacante los localiza, los lee o exfiltra directamente | *ALTO* Clínica de 20 empleados sin indicios de capacitación en seguridad; un solo clic compromete credenciales de acceso | *ALTO* IoT, servidores y estaciones de trabajo comparten la misma red plana, sin VLANs, ni firewall interno |
| **Impacto Técnico según la Triada CIA** | *ALTO* Pérdida total de control sobre | *ALTO* Cifrado masivo de bases de | *ALTO* Pérdida total de confidencialida | *ALTO* Vector de entrada típcio para | *ALTO* Un solo punto de entrada alcanza el |

| | | | | | |
|---|---|---|---|---|---|
| | dispositivos de monitoreo médico | datos de historiales médicos | d, ya que los respaldos contienen la misma información sensible como la de los historiales originales | desplegar Ransomware o robar credenciales de acceso al servidor | servidor de historiales médicos |
| **Impacto en el Negocio** | *CRÍTICO* Demanda por negligencia médica, pérdida de vidas, cierre temporal. | *CRÍTICO* Multas regulatorias severas, extorsión por Ransomware, parálisis operativa. | *CRÍTICO* Convierte un ataque de cifrado en una fuga de datos, agravando sanciones regulatorias. | *CRÍTICO* Puede ser el origen mismo del incidente descrito en el escenario; habilita todos los demás riesgos | *CRÍTICO* Amplifica el alcance de cualquier otro ataque: lo que debería ser un incidente aislado se vuelve una brecha total |
| ***Nivel de Riesgo*** | ***CRÍTICO*** | ***CRÍTICO*** | ***CRÍTICO*** | ***CRÍTICO*** | ***CRÍTICO*** |

En retrospectiva, la clínica presenta una postura de riesgo extremadamente alta debido a fallas básicas de control de acceso y falta de endurecimiento en servidores locales.

## Normativas

1. **LFPDPPP:** Obliga a implementar medidas de seguridad administrativas, físicas y técnicas para proteger datos personales, especialmente los datos sensibles. Una brecha de esta magnitud requiere notificar a titulares y autoridades correspondientes.
2. **ISO/IEC 27001:** Evalúa la gestión de riesgos, controles de acceso, cifrado y políticas de respaldo.
3. **ISO 27799:** Extensión específica de la norma anterior, enfocada en la gestión de la seguridad de la información en el sector salud.
4. **HIPAA:** Dentro de la perspectiva estadounidense, la ley HIPAA exigen cifrado de datos en reposo y tránsito, controles de acceso estrictos y planes de respuesta a incidentes para Ramsomware.
5. **GDPR:** Dentro de la perspectiva europea, la ley establece multas severas (hasta 20M de Euros o el 4% de facturación global anual) por no proceder al reporte en 72 horas.

# Vulnerabilidades

## GoPhish



```
Mime-Version: 1.0
Date: Mon, 02 Nov 2026 07:09:44 -0500
Message-Id: <1793621384954209585.34408.16433561102344621 72@kali>
Subject: Actualizacion critica de Software requerida
To: "Alfredo Osorio" <freddyfazbear@clinica.com>
From: soporte@clinica.com
X-Mailer: gophish
Content-Transfer-Encoding: quoted-printable
Content-Type: text/html; charset=UTF-8
X-Peer: ('::1', 56214, 0, 0)

<p>Estimado colaborador,</p>
<p>Se ha detectado una vulnerabilidad critica en los servidores de la clini=
ca. Es obligatorio aplicar el parche de actualizacion inmediata a trav[es d=
el siguiente portal interno:</p>

<p><a href=3D"http://10.0.2.15?rid=3DaXiWucR">ACTUALIZAR SISTEMA MEDICO AHO=
RA</a></p>

<p>Atentamente,<br>Departamento de TI</p>
```

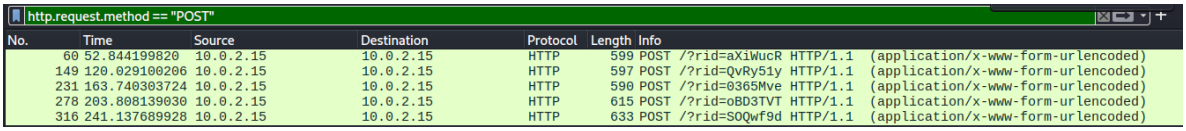
| | First Name | Last Name | Email | Position | Status |
|---|---|---|---|---|---|
| ▸ | Alfredo | Osorio | freddyfazbear@clinica.com | Adminsitrativo | Submitted Data |
| ▸ | Bonifacio | Gonzalez | bonnie@clinica.com | Enfermero | Submitted Data |
| ▸ | Chica | Pineda | pizza@clinica.com | Enfermero | Submitted Data |
| ▸ | Furcio | Zorrendo | argh@clinica.com | Recepcion | Submitted Data |
| ▾ | Margarita | Zazueta | mangle@clinica.com | Tecnico de Soporte | Submitted Data |

Se configuró una campaña de Phishing simulado dirigida a 5 destinatarios ficticios (usando nombres sacados de la franquicia Five Nights at Freddy's), usando una plantilla de correo que suplanta al departamento de soporte técnico con el asunto "Actualización crítica de Software requerida" y un enlace de rastreo único por destinatario. El panel de resultados de la campaña arrojó dos hallazgos relevantes:

1. Una tasa de clic del 100%, lo que evidencia una ausencia total de capacitación en concientización sobre el phishing dentro del personal de la clínica.
2. Una tasa de envío de datos del 100%, los 5 destinatarios llegaron a completar el formulario señuelo de "Reautenticación de credenciales". Esto prueba que, en el caso de llevarlo a la escala real, el compromiso de credenciales sería total.

Estos resultados validan la amenaza de "Phishing a Empleados" clasificada como CRÍTICA en la matriz OWASP de la sección anterior.

# Wireshark



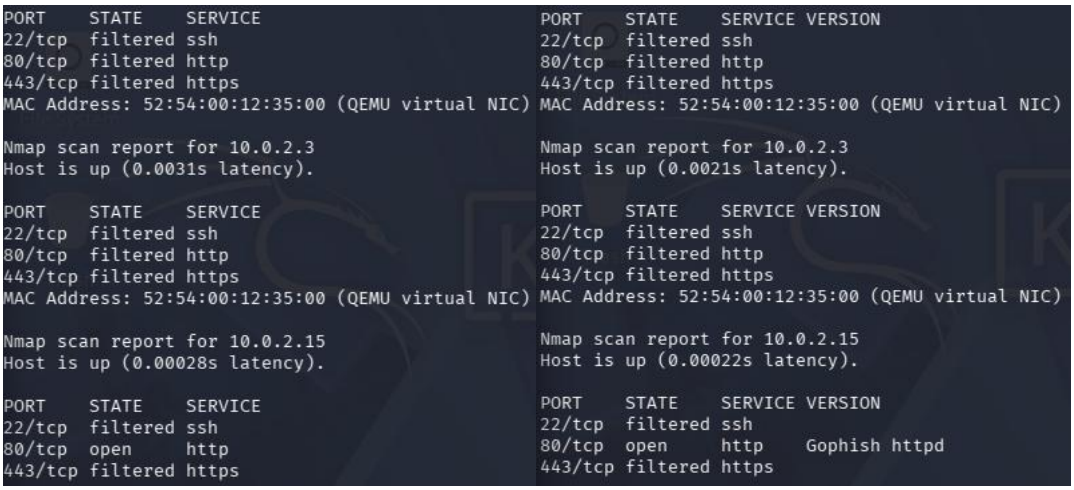
http.request.method == "POST"

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 60 | 52.844199820 | 10.0.2.15 | 10.0.2.15 | HTTP | 599 | POST /?rid=aXiWucR HTTP/1.1 (application/x-www-form-urlencoded) |
| 149 | 120.029100206 | 10.0.2.15 | 10.0.2.15 | HTTP | 597 | POST /?rid=QvRy51y HTTP/1.1 (application/x-www-form-urlencoded) |
| 231 | 163.740303724 | 10.0.2.15 | 10.0.2.15 | HTTP | 590 | POST /?rid=0365Mve HTTP/1.1 (application/x-www-form-urlencoded) |
| 278 | 203.808139030 | 10.0.2.15 | 10.0.2.15 | HTTP | 615 | POST /?rid=oBD3TVT HTTP/1.1 (application/x-www-form-urlencoded) |
| 316 | 241.137689928 | 10.0.2.15 | 10.0.2.15 | HTTP | 633 | POST /?rid=SOQwf9d HTTP/1.1 (application/x-www-form-urlencoded) |

Durante la campaña, se capturó el tráfico de red aplicando el filtro `http:request.method == "POST"`, con la finalidad de monitorear el envío de datos hacia la página de aterrizaje señuelo. El análisis arrojó dos conclusiones:

1. Se identificaron 5 peticiones POST, una por cada destinatario ficticio que completó el formulario, dirigidas al servidor GoPhish (10.0.2.15); al inspeccionar el contenido de los paquetes se observan campos de Usuario y Contraseña viajando en texto plano, sin ningún tipo de cifrado. Eso pone en evidencia sobre cómo el factor humano siempre es el eslabón más vulnerable.
2. A diferencia del ejemplo del escenario (conexión hacia una IP sospechosa), en este entorno, el tráfico permanece dentro de la red local, debido a recursos limitados. Sin embargo, en un ataque real contra una institución hospitalaria o de infraestructura crítica, el filtro detecta conexiones salientes hacia una IP externa no autorizada, correspondiente al servidor de mando y control del atacante.

# Nmap



```
PORT    STATE    SERVICE
22/tcp  filtered ssh
80/tcp  filtered http
443/tcp filtered https
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.3
Host is up (0.0031s latency).

PORT    STATE    SERVICE
22/tcp  filtered ssh
80/tcp  filtered http
443/tcp filtered https
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.15
Host is up (0.00028s latency).

PORT    STATE    SERVICE
22/tcp  filtered ssh
80/tcp  open     http
443/tcp filtered https
```

```
PORT    STATE    SERVICE VERSION
22/tcp  filtered ssh
80/tcp  filtered http
443/tcp filtered https
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.3
Host is up (0.0021s latency).

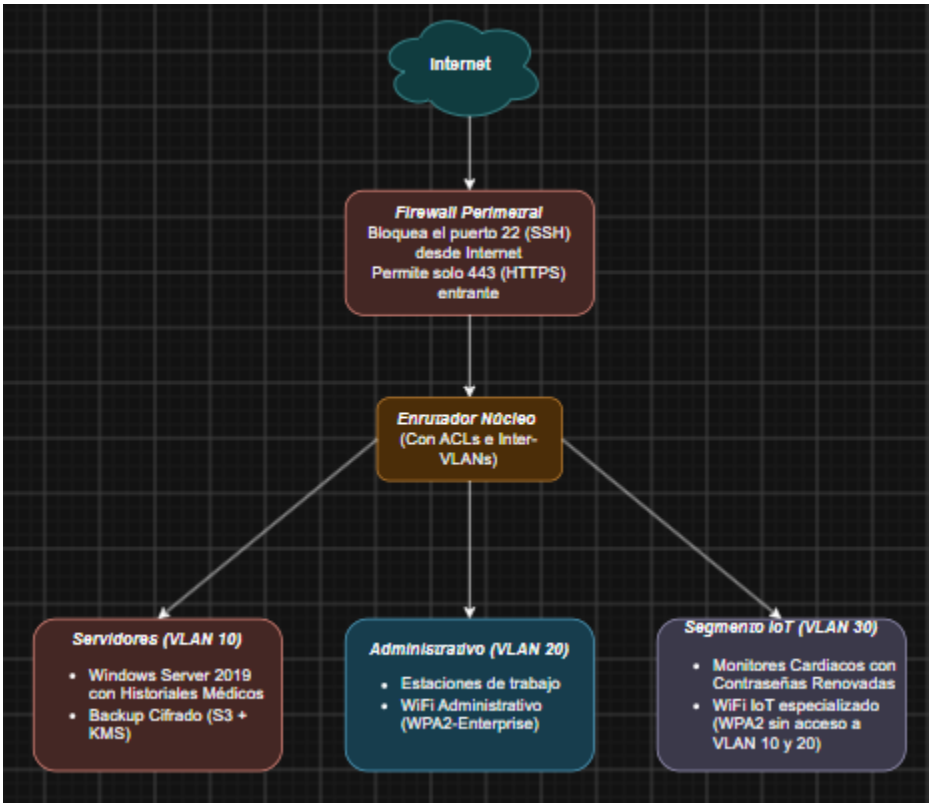
PORT    STATE    SERVICE VERSION
22/tcp  filtered ssh
80/tcp  filtered http
443/tcp filtered https
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)

Nmap scan report for 10.0.2.15
Host is up (0.00022s latency).

PORT    STATE    SERVICE VERSION
22/tcp  filtered ssh
80/tcp  open     http    Gophish httpd
443/tcp filtered https
```

El escaneo reveló que el host 10.0.2.16 expone el puerto 80/TCP ejecutando GoPhish httpd, confirmado mediante detección de versión (-sV, el de la derecha). El nivel de exposición (servicio identificable sin autenticación previa) replica el riesgo descrito en el escenario, donde los monitores cardiacos exponen banners de servicio sobre Wi-Fi sin protección, facilitando el reconocimiento por parte de un atacante.

# Diagrama




Como parte de la estrategia de mitigación y endurecimiento de la infraestructura de la clínica, se diseñó una arquitectura de red segmentada para limitar la superficie de ataque y prevenir movimientos laterales en caso de un nuevo incidente de seguridad.

1. **Perímetro y Control de Acceso Perimetral:** Se bloquea el Puerto 22 (SSH) para bloquear cualquier petición extraoficial de la organización, pero manteniendo el Puerto 443 (HTTPS) para permitir la entrada de peticiones autorizadas.
2. **Enrutamiento y Control de Tráfico Inter-VLAN:** El tráfico entre las diferentes zonas de la red es gestionada por un Enrutador Núcleo, aplicando Listas de Control de Acceso estrictas para regular la comunicación entre el Internet y las Segmentaciones.
3. **Segmentación por Zonas (VLANs):**
    a. *Servidores Críticos (10):* Aloja el servidor local bajo Windows Server 2019 que contiene historiales médicos y protegidos mediante políticas estrictas.
    b. *Zona Administrativa (20):* Agrupa estaciones de trabajo de los 20 colaboradores de la clínica mediante WPA2-Enterprise para evitar casos de suplantación de identidades.
    c. *Segmento IoT (30):* Aisla físicamente los monitores cardiacos y dispositivos conectados por Wi-Fi. El segmento cuenta con contraseñas renovadas y está bloqueado mediante reglas de enrutamiento para que no haya vulnerabilidades hacia los Servidores y la Administración.